



UnionPay Integrated Circuit Card Specifications

— Auxiliary Specifications

**Part VIII UnionPay Integrated Circuit
Card Multiple Applications General Security Guide**



Version 2014

THIS PAGE IS INTENTIONALLY LEFT BLANK.

Table of Contents

1 APPLICATION SCOPE.....	1
2 REFERENCES.....	2
3 TERMS AND DEFINITIONS.....	3
4 SYMBOLS AND ACRONYMS	6
5 MULTI-APPLICATION FINANCIAL SMART CARD MANAGEMENT MODEL.....	7
5.1 CARD LIFE CYCLE	7
5.2 MULTI-APPLICATION FINANCIAL SMART CARD LIFE CYCLE.....	7
5.2.1 Bank as Issuer Entity.....	10
5.2.2 Management Model with Multi-Party Cooperation	10
6 MULTI-APPLICATION FINANCIAL SMART CARD OVERALL SECURITY REQUIREMENTS	12
6.1 SMART CARD OS SOFTWARE DEVELOPMENT STAGE.....	12
6.2 SMART CARD ISSUANCE STAGE	12
6.3 SMART CARD USAGE STAGE.....	13
7 MULTI-APPLICATION FINANCIAL SMART CARD APPLICATION MANAGEMENT SECURITY FRAMEWORK.....	14
7.1 MULTI-APPLICATION SECURITY FRAMEWORK	14
7.1.1 Operating Environment	14
7.1.2 Operating Environment API.....	15
7.1.3 Card Management Security Interface.....	15
7.1.4 Security domain.....	15
7.1.5 Application	16
7.1.6 Encryption Service	16
7.2 ENCRYPTION SERVICE	16
7.2.1 Integrity Certification.....	16
7.2.2 Confidentiality.....	17
7.2.3 Security Message.....	17
7.3 SECURE COMMUNICATION MECHANISM.....	17
7.3.1 Entity Authentication.....	17

7.3.2 Integrity Certification.....	17
7.3.3 Cryptogram Transfer	18
7.4 LIFE CYCLE MODEL	18
7.4.1 Card Life Cycle.....	18
7.4.2 Executable Download File / Executable Module Life Cycle	18
7.4.3 Application and Security Domain Life Cycle	19
7.5 APPLICATION SECURITY	23
7.5.1 Pre-installed Applications	24
7.5.2 Dynamic Load Applications	25
8 MULTI-APPLICATION FINANCIAL SMART CARD SECURITY REQUIREMENTS	29
8.1 MULTI-APPLICATION FINANCIAL SMART CARD SECURITY ENVIRONMENT	29
8.2 SECURITY THREATS AND ATTACKS	29
8.3 SECURITY GOALS	31
8.4 SECURITY REQUIREMENTS	33
8.4.1 Security Functionality Requirements.....	33
8.4.2 Chip Security Requirements	36
8.4.3 COS Security Requirements.....	38
8.4.4 Multi-application Financial Smart Card Security Protection Requirements.....	43

1 Application Scope

This book applies to all UPI Participants.

2 References

The clauses in the following document, which are referenced by this specification, are considered to be part of this specification. For any dated references, follow-on amendments (excluding error corrections) or revisions do not apply to this specification. However, parties who reach agreement through this book are encouraged to analyze whether the latest edition of these documents could be utilized. For undated references, the latest version applies to this book.

<i>ISO/IEC 7816-4:2005</i>	<i>Identification cards -- Integrated circuit cards</i>
<i>UICS</i>	<i>UnionPay Integrated circuit card specifications</i>

3 Terms and Definitions

Smart Card (SC)

IC card with secure calculation unit and secure storage.

Smart Card Payment

Payment service that uses smart cards stored with financial data for security authentication.

Application

Application protocol and relevant datasets between the card and the terminal.

APDU (Application Protocol Data Unit)

Protocol data unit (PDU) refers to the data units transferred between equivalent levels. Application protocol data unit (APDU) is the data unit transferred between the smart card and the card reader.

Secure Element

Main component of smart IC cards, mainly responsible for secure storage of key transaction data and calculation functionality.

Flash Memory

A kind of read-only storage electronics format that is erasable and programmable, permitting multiple rewrites during operation. Mainly used to store general data, as well as exchange of data between computers and other digital products, such as memory cards and flash memory cards. Flash memory is a special type of EEPROM capable of being rewritten in macro block.

Random access memory

RAM, where storage unit content can be retrieved or saved at will, and access speed is independent of storage unit location. This type of memory loses its stored content when power is cut off, mainly used for storing programs to be used over a short period.

Key

A set of symbols that control operations during encryption and decryption.

Digital Certificate

Public key info signed by a certificate authority that could not be forged.

Digital Signature

A type of asymmetric conversion of data. This conversion can let the data recipient confirm the source and integrity of the data, ensuring that the data sent and the data received are not tampered with.

Application Owner

Organizes developers to develop applications, and maintains application, entity that owns the application control rights.

Application Provider

Entity that implements application and provides download files or keys for application installation.

Confidentiality

Information cannot be leaked to unauthorized entity.

Integrity

Data was not changed or destroyed due to un-authorized means.

Security Attribute

Subject, user, object, data, and other resource type feature parameters used to define security functionality and implement security strategy.

Card Issuer

Organization that issues the card to the users.

Card Manufacturer

Entity that relies on card issuer to manufacture cards.

Life Cycle

A set of all possible states for the smart card or application.

Locked

Application locked state, only authorizer with administrative rights can unlock this state.

Unlocked

Locked state unlocked with authorization key, restore to usable state.

Terminated

Final life cycle state, card or application could no longer be used.

Key Management System

Platform or application related key management provided based on card issuer's interests.

4 Symbols and Acronyms

AID	Application Identifier
AP	Application Processor
APDU	Application Protocol Data Unit
COS	Chip Operation System
KEK	Key encryption key

5 Multi-application Financial Smart Card Management Model

5.1 Card Life Cycle

Smart card development and manufacturing can be divided into the following stages:

- Development stage: development of smart card embedded software and application; IC circuit design, development, and mask manufacturing.
- IC circuit production stage: smart card chip manufacturing, testing, and assembly stage.
- Smart card production stage: smart card packaging, printing, processing, and personalization prep stage.
- Smart card issuance and personalization stage: download specified user data to smart card storage.
- Smart card end user stage: this stage includes (multi-) application download and management, card locking, unlocking, and termination.

Multi-application financial smart card development and manufacturing stage mainly includes the smart card personalization stage and smart card end use stage. Once multi-application financial smart card completes personalization, the multi-application financial smart card can function normally. Card is configured with card issuer applications and functionality, with all private keys and security keys downloaded into the card, so the card enters a secure state; in this secure state, the card can be given to end user for use, can install other application programs, including industry applications, bank financial applications, and commercial application provider applications. The card can run several applications from the issuer, several applications from the application provider, as well as several applications that provide overall services.

5.2 Multi-application Financial Smart Card Life Cycle

Multi-application financial smart card refers to the smart card that loads other industry applications besides financial applications that realize debit/credit functionality, such as social security, transportation, telecom, and other applications. This kind of smart card exists within a complex life cycle, with several entities creating suitable eco-system in the development, production, and usage stages. Smart card life cycle has chip manufacturer, card manufacturer, card issuer, key management org, card enabler, application provider, application owner, user, and other entities mutually cooperating based on various smart card management models, maintaining a complete eco-system.

For Java card, cards, its lifecycle is as shown in the figure below

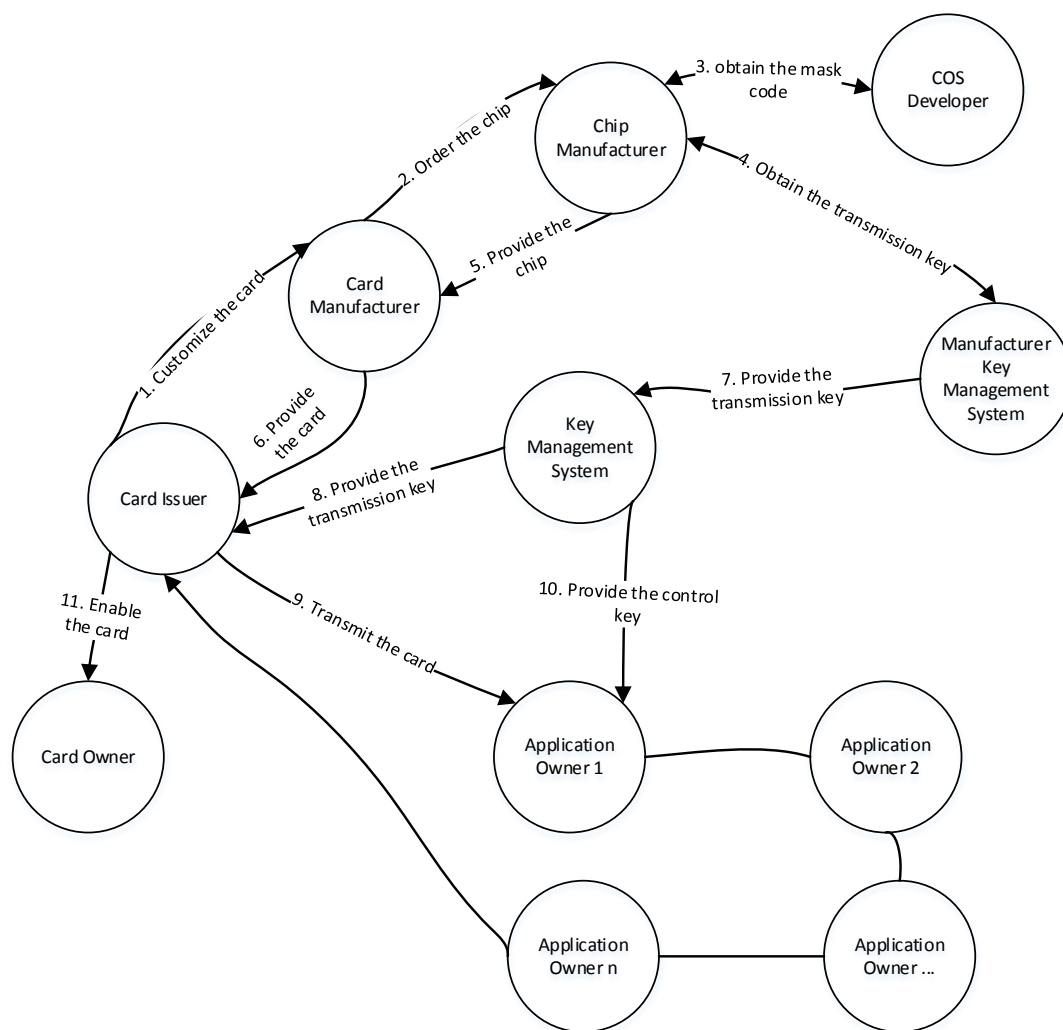


Figure 1 Java card life cycle

- (1) The card issuer orders cards from the card manufacturer.
- (2) Upon receiving the order, the card manufacturer orders chips from the chip manufacturer.
- (3) To manufacture chips, the chip manufacturer needs to obtain the mask code from the platform developer.
- (4) The chip manufacturer needs to obtain the initial transmission key from the key management department of the manufacturer. In addition to the chip manufacturer, the key management department also needs to provide the initial transmission key to the card enabler.
- (5) Upon receiving the chips, the card manufacturer starts to manufacture cards.
- (6) The card manufacturer provides the cards to the card issuer.

- (7) The platform key management department needs to obtain the card initial transmission key from the key management department of the manufacturer before providing the card enabling data and the key.
- (8) Upon obtaining the cards, the card issuer needs to apply to the platform key management department for the card enabling data or the key.
- (9) After the cards and the card enabling data have been transmitted to the card enabler, the card enabler carries out card initialization based on the initial transmission key and returns the usable cards to the card issuer.

For Native cards, its lifecycle is as shown in the figure below:

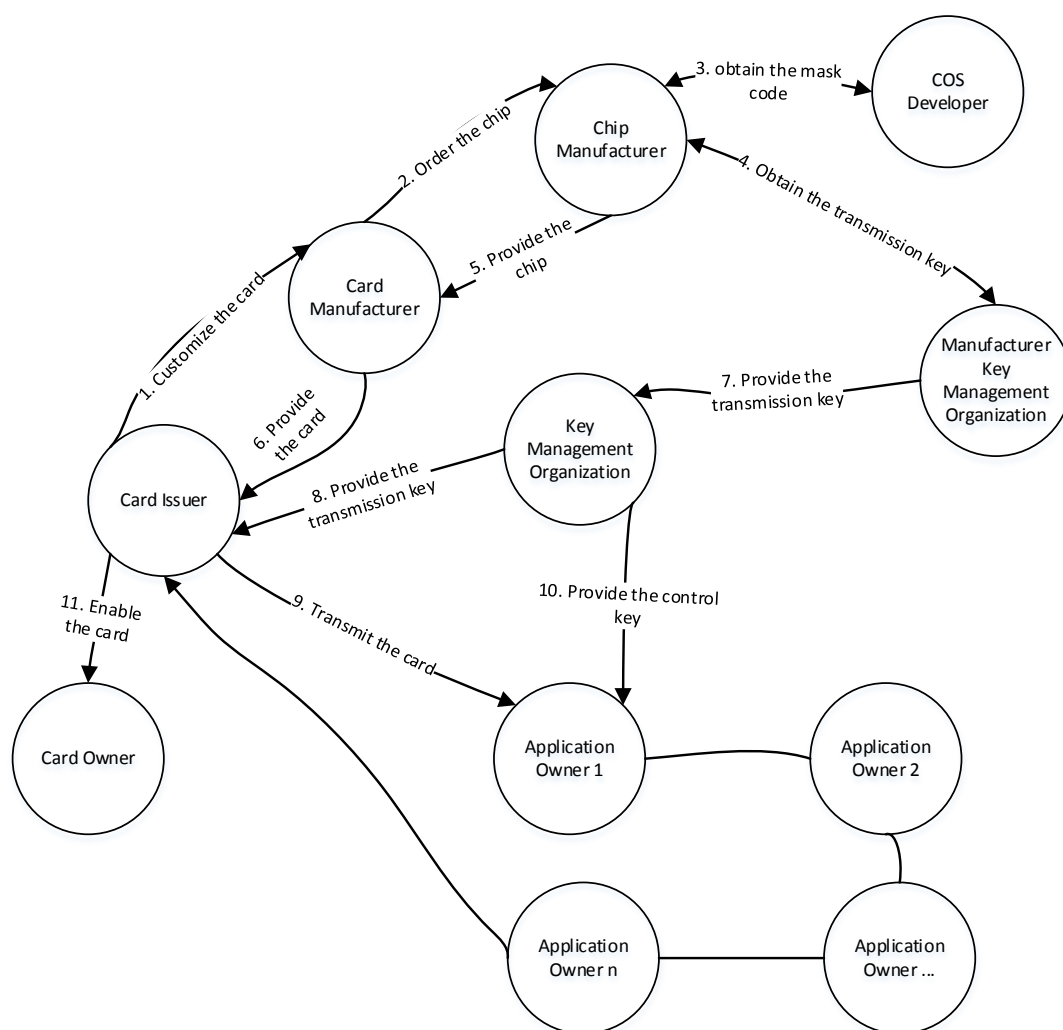


Figure 2 Multi-application financial smart card life cycle

- (1) Card issuer initiates card order request to card manufacturer.
- (2) After receiving the order request, card manufacturer orders chip from the chip manufacturer.

- (3) To create chip, the chip manufacturer needs to obtain mask code from COS developer.
- (4) Manufacturer key management org provides initial transfer key needed by chip manufacturer. While the manufacturer key management org provides chip manufacturer with initial transfer key, it also provides initial transfer key to card enabler.
- (5) Card manufacturer obtains chip post-production card from the chip manufacturer.
- (6) Post-production card is provided to the card issuer by the card manufacturer.
- (7) Prior to key management org providing card enabling data and key, it must obtain the card initial transfer key from the manufacturer key management org.
- (8) After the card issuer obtains the card, it must request the card transfer key from the key management org.
- (9) Then the card is sent to application owner, who, through using rights obtained through authenticating the key from the key management org, creates its own application, personalizes its own application data. The various applications issued by application owners co-exist with no dependencies on precedence.
- (10) Application owner obtains rights key from key management org.
- (11) Card issuer enables card then issues them to card owners.

5.2.1 Bank as Issuer Entity

In the management model where the bank is the issuer entity, card control keys for multi-application financial smart card are managed by the card issuer, card personalization, card application download, install, and deletion, plus card key management are all controlled by the card issuer. This management model can be extended through managerial delegation, agency entrustment, and other forms, resulting in more varied and specific management models to meet actual demands.

5.2.2 Management Model with Multi-Party Cooperation

In a multi-party cooperation management model, the different organizations and industries can manage multi-application financial smart cards through cooperation as equals. Each cooperating party can freely personalize multi-application financial smart cards under secure conditions, can download/install applications, manage keys, and other operations, while multi-application financial smart card security would be the joint responsibility of all cooperating parties. This management model can form more varied and specific management models based on specific circum-

stance, such as absolute or relative equality between organizations, and whether the card internal resource allocation is evenly shared between organizations, etc.

6 Multi-application Financial Smart Card Overall Security Requirements

6.1 Smart Card OS Software Development Stage

In the card development stage, the confidentiality and integrity of smart card OS software code transferred from the developer to the smart card manufacturer must be ensured. Since the smart card operating system software developer and smart card manufacturer both obtain transfer keys from the key management org, the key management org shall also ensure the security of the means for key generation, maintenance, and transfer. Smart card operating system software code developer, smart card manufacturer, and key management org must all ensure security of code/key transfer and storage.

If the smart card OS software utilizes platform and application frameworks, then during independent platform and application development, the developer must ensure the security of application development process (e.g. application code must not be illegally leaked) and the security of application code storage and transfer; application security must also be ensured, including whether the application is being coded using secure API provided by the platform, and whether application code has been signed for receiving party verification prior to transfer. Transfer of application code and data between application provider and application download org also requires establishment of secure channel to ensure confidentiality of data transfer. And application developer must not leave backdoor commands in the application beyond specification requirements.

6.2 Smart Card Issuance Stage

Card issuance stage, depending on different models (centralized or distributed issuing model). There can be one or multiple issuers. Issuer must maintain user data confidentiality, including user account numbers, passwords, and other data. For centralized card issuance, the sole issuer must ensure application data and keys are segregated during transfer and card write-in. In distributed card issuing mode, the card issuer can only write in its proprietary application data and keys, and can not modify or damage the data or keys of other applications in the card.

When transferring data, issuer and other organizations must use secure channel for secure data exchange. If issuer obtains card enabling data and key from key management org, or if the issuer transfers card key to the card enabling org, the security of the channel must be ensured.

Card must provide data transfer security protection mechanism, to ensure the confidentiality of data and key transfer during issuance. Card must provide secure access control, prohibit unauthorized creation, modification, or deletion of application data and keys.

6.3 Smart Card Usage Stage

Smart card usage stage includes the adding, deleting, and operating of applications. The adding and deleting of application requires the application shall be implemented using secure communication mechanism, provided by application download organization. Application's own secure operation must follow the specifications for each application, with cards providing security mechanisms to ensure secure operation. Meanwhile, secure access control shall be implemented. Unauthorized access or modification of application code and keys shall be prohibited.

7 Multi-application Financial Smart Card Application Management Security Framework

7.1 Multi-application Security Framework

Multi-application financial smart card application management security framework provides a multi-application security management framework that can be used by multiple parties, ensuring secure management of application programs and application data for different application providers on the financial smart card.

Multi-application financial smart card requires the multiple applications in the card be implemented on a single secure card platform, with secure framework composed of operating environment, operating environment API, card management secure interface, secure domain, and various applications. Therein, operating environment, operating environment API, card management secure interface, and at least one secure domain (issuer secure domain) make up the multi-application financial smart card platform, providing a hardware platform independent security framework for multiple applications, also responsible for smart card security protection, to protect multi-application financial smart card internal code and data from outside attack.

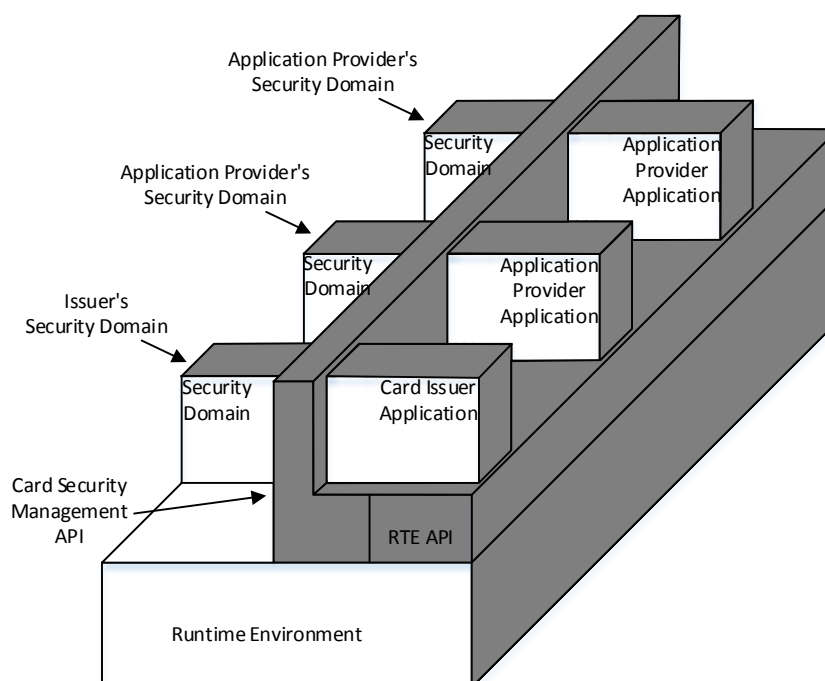


Figure 3 Multi-application Security Architecture

7.1.1 Operating Environment

Secure operating environment controls the allocation and management of memory and other hardware resources, providing secure storage and execution space for various applications, keeping the code and data of different applications segregated, or engaged in constrained secure information exchange. When storage space is released for reuse, it must ensure the storage space content is not leaked. When ab-

normal power or unplugging occurs during card operation, it must ensure the memory recovery process is secure.

In order to ensure that there is no mutual interference between the different applications, implementation of application firewalls is required for the various application code and data, (open) data and program code could not be accessed by other applications without permission. Strictly follow the dependency relationship and access conditions of each application, checking the varied restrictions and dependency relations for each application prior to application download; during application operation, also strictly restrict the current content environment and resource access boundaries.

Operating environment must ensure that its security mechanism could not be circumvented, disabled, damaged, or otherwise avoided.

Operating environment also provides a set of application program interfaces and related services independent from hardware chip and platform provider, providing for application development from application providers.

7.1.2 Operating Environment API

Each application uses operating environment API to access the various services and hardware resources provided by the operating environment, such as communication interfaces, memory, encryption services, etc.

7.1.3 Card Management Security Interface

Card management security interface uses standardized API to provide applications with various services, such as personalization service, security service, card content management service, etc. Card content management includes the download, install, and deletion of card content, as well as changes in application life cycle state, etc. It must ensure that its security mechanism could not be circumvented, disabled, damaged, or otherwise avoided.

7.1.4 Security domain

Security domain is a representative of the issuer and its application provider on the multi-application financial smart card, providing each application with security services: for example, key processing, encryption, and decryption, providing digital signatures and verification for application owners, allowing issuer and application providers to use mutually independent key sets, independently managing their own applications and data.

Each secure domain shall implement security channel protocol, thereby ensuring communication security between multi-application financial smart card external entity and the secure domain on the multi-application financial smart card.

Security domain can provide encryption protection service for its application during pre-personalization.

Security domain can also provide applications with a standard external interface to access services provided by secure domain, making it possible for multi-application financial smart card external management system to manage multi-application financial smart cards implemented by different manufacturers in a standard way.

7.1.5 Application

Based on different operator rules, applications may be installed at different stages of the multi-application financial smart card life cycle, and also may not be permitted to download or install during certain life cycle stages (e.g. after card issuance) due to other industry requirements. Application to be installed may be completely segregated, but also may engage in controllable interoperations under certain conditions.

Applications that are already installed onto the card before the issuance of multi-application financial smart cards are referred to as pre-installed applications; those applications that are installed onto the card only after financial smart card issuance are called dynamic loaded applications.

7.1.6 Encryption Service

Multi-application financial smart card application management security framework must be able to provide relevant password functionality, such as the generation of digital signature, symmetrical encryption/decryption, asymmetrical encryption/decryption, etc., using these password functionalities to provide applications with the following encryption services:

1. Integrity certification
2. Confidentiality
3. Security message

7.2 Encryption Service

7.2.1 Integrity Certification

Integrity certification means: sender uses some method such as cryptography, to generate an check value for relevant message or data block (application code or application data). Through this check value the receiver can verify source data, determine whether the specified message or data block (application code or application data) has been modified during the transfer process, and whether it is complete.

Integrity certification utilizes cryptography methods including Hash, digital signature, MAC implemented by DES operation, etc.

7.2.2 Confidentiality

Confidentiality refers to: A sender performs encryption processing on message data field or sensitive data region, to ensure that the data transferred can not be seen by unauthenticated entities; receiver must decrypt to receive the plaintext data.

7.2.3 Security Message

Security message refers to: Permit a sender entity to encrypt the sensitive data of the message and add integrity certification mechanism prior to sending the message, and assemble data that match confidentiality and/or integrity certification mechanism into APDU message to send to a receiver entity.

Security message can be implemented through the following method:

1. Add integrity certification method to an APDU command sent to the card, or simultaneously add confidentiality and integrity certification method to an APDU command sent to the card.
2. In a secure channel session, add integrity certification mechanism to a series of APDU commands (APDU command sequence) sent to the card.
3. Optionally, add confidentiality and/or integrity certification mechanism to an APDU response message sent to the card; in a secure channel session, add integrity certification mechanism to a series of APDU responses (APDU response sequence). This is determined by the security channel protocol used.

7.3 Secure Communication Mechanism

Using the encryption service described above, multi-application financial smart card application management security framework can establish a secure communications environment, allowing multi-application financial smart cards to engage in secure information exchange with external entities. The different stages of the life cycle determine the secure communication grade of the multi-application financial smart card with external entities.

7.3.1 Entity Authentication

Unidirectional or bi-directional multi-application financial smart card and external entity, ensuring that the sender entity and/or receiver entity engaged in data exchange are trusted entities.

7.3.2 Integrity Certification

A receiver entity (multi-application financial smart card or external entity) through cryptography method ensure that the data from a sender entity (multi-application financial smart card or external entity) really comes from an authenticated entity, and the data had not been tampered with.

7.3.3 Cryptogram Transfer

Data sent by a sender entity (multi-application financial smart card or external entity) to a receiver entity (multi-application financial smart card or external entity) is transferred in the form of cryptogram, so that it is not visible to un-authenticated entities.

7.4 Life Cycle Model

The life cycle model includes the following components:

1. Card
2. Executable download file / executable module
3. Application and secure domain

Because multi-application financial smart cards may be pre-installed with some applications, and may dynamically download some applications after card issuance, the life cycle state model for each assembly is relatively symmetric. How to execute downloaded file/executable module assembly's life cycle state may exist in the card's pre-issuance preparation stage, initial completion stage, and also may exist in the post-issuance secure state stage; similarly, application life cycle state may also exist in the card's pre-issuance preparation stage, initial completion stage, and also may exist in the post-issuance secure state stage.

7.4.1 Card Life Cycle

For card life cycle detailed description please refer to Section 5.1.

7.4.2 Executable Download File / Executable Module Life Cycle

Executable download file/executable module is one or more executable code (executable module) in actual storage format, with only one life cycle state, as below:

1. "Downloaded".

For EXECUTABLE LOAD FILES/EXECUTABLE LOAD MODULES stored in volatile memory, physical space can be released, and can be reused, an example being the storage in EEPROM or FLASH that can be deleted and the space reused; for EXECUTABLE LOAD FILES/EXECUTABLE LOAD MODULES stored in persistent memory, these can not be deleted, but rather related record info that is deleted, for example data stored in ROM can not be deleted. Regardless of whether the storage is which medium, the corresponding registered record info from the registry will always be deleted.

7.4.2.1 Executable Download File "Downloaded" State

A download file, through the APDU command, is securely and completely transferred and stored on card, also associated with relevant secure domain, is considered to be in the "Downloaded" state.

7.4.2.2 Deletion of Executable Download File

If multi-application financial smart card receives a request to delete executable download file, then all related info to the executable download file/executable module needs to be deleted, multi-application financial smart cards can not retain or leak any related records to the executable download file/executable module; the physical space previously taken up by the executable download file/executable module shall be released for reuse.

If the request received by the multi-application financial smart card calls for the deletion of every application instantiated from executable download file/executable module, for details see Section 7.4.3.1.4 "Delete Application".

7.4.3 Application and Security Domain Life Cycle

The life cycle for an application or secure domain begins when the application is instantiated.

In the application installation process, when one application is instantiated, the application life cycle state is set to be the initial "Installed" state; in the process of application installation, when an application can be selected, this application's life cycle state is set to "Selectable"; once application can be selected, its life cycle will be controlled by the application itself.

Application or secure domain life cycle state control or change both require secure protection to proceed; at the same time external entity can also inspect relevant application or secure domain life cycle state through the standardized card security management interface.

7.4.3.1 Application Life Cycle State

An application's life cycle includes the following states:

1. "Installed"
2. "Selectable"
3. "Locked"

Besides these, the application can define its own special life cycle states, such as application personalization state.

Once the application reaches the "Selectable" state, its lifecycle next state shall be managed by the application itself; so long as there is no conflict with the aforementioned application life cycle state definition, the application can also use and independently management self-defined life cycle states, ensuring the security of state changes.

The figure below is the application life cycle state change diagram.

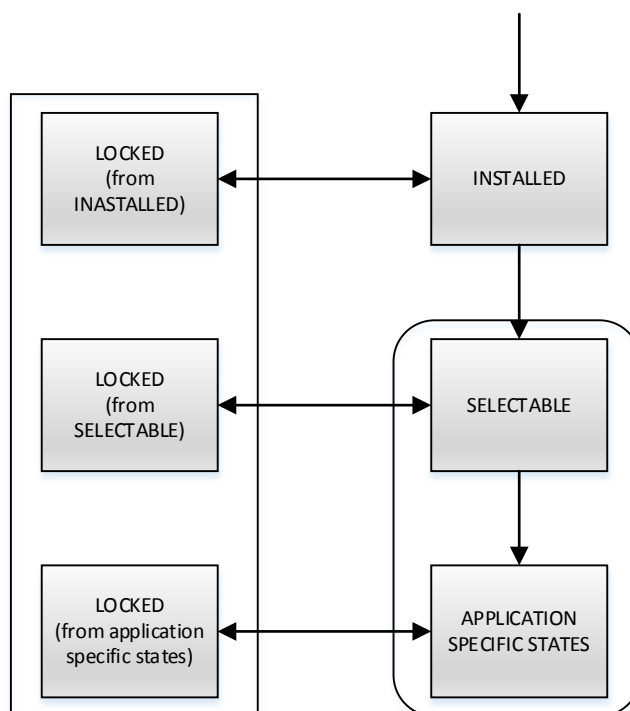


Figure 4 Application Life Cycle State Transitions

7.4.3.1.1 Application "Installed" State

Application in "Installed" state means: application executable code has completed correct dynamic links and the necessary storage resource allocation is complete, but application is not yet ready to be selected. Application installation process shall not be combined with application personalization, as application personalization shall be an independent process.

7.4.3.1.2 Application "Selectable" State

Application in "Selectable" state means: Application can be selected and receive commands from external entities. Application "Installed" state and "Selectable" state are not reversible. Prior to setting an application to "Selectable" state, it must be correctly installed. Change to "Selectable" state may be included in the install process of the application.

7.4.3.1.3 Application "Locked" State

Application "Locked" state is used for security management control, to prevent this application from being selected and executed.

Considering business or security factors, if a threat related to a specific application is detected, the application may be put into "Locked" state to prevent further selection, execution, or other operation of this application.

When application is unlocked, the application shall resume its state prior to being locked.

7.4.3.2 Application Deletion

In any state of the application life cycle, multi-application financial smart card can always receive request to delete application.

If multi-application financial smart card receives request to delete application, then all related data of the application must be deleted, multi-application financial smart card must not retain or leak any relevant records of the application; at the same time physical space previously utilized by the application can be released for reuse.

7.4.3.3 Security Domain Life Cycle State

A security domain's life cycle includes the following states:

1. "Installed"
2. "Selectable"
3. "Personalized"
4. "Locked"

Security domains are not allowed to have self-defined private states.

The figure below is the state transition diagram of the security domain in its life cycle.

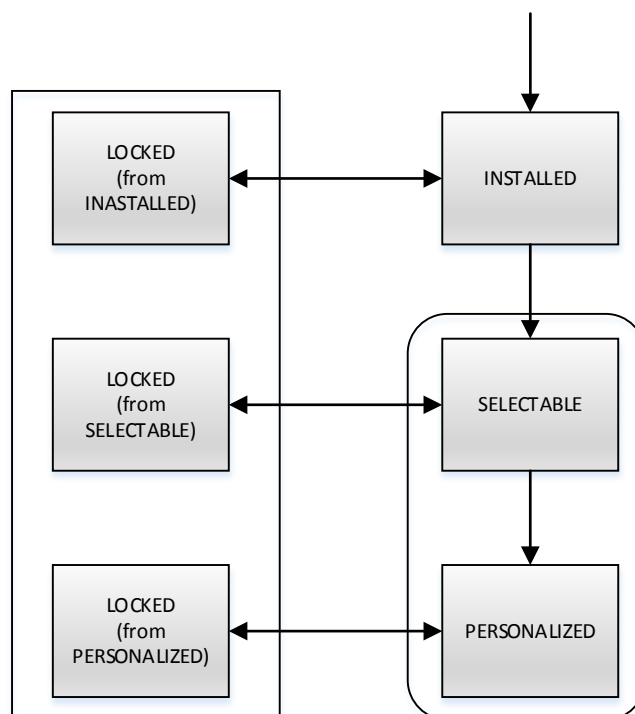


Figure 5 Security Domain Life Cycle State Transitions

7.4.3.3.1 "Installed" State of Security Domain

"Installed" state implies: Security domain's executable code has been registered on the card, but in this state the security domain cannot be selected, and has yet to be associated with executable download files or applications; therefore the services provided by this security domain could not be used by applications.

7.4.3.3.2 "Selectable" State of Security Domain

"Selectable" state implies: Security domain can be selected and is capable of receiving commands from external entities (especially personalization command). In this state, because the security domain key has yet to be installed, and there are no associations with executable download file or application, the services provided by this security domain could not be used by applications.

"Installed" state and "Selectable" state are not reversible. Prior to setting a security domain to "Selectable" state, it must be correctly installed. The security domain may be set to "Selectable" state in its installation process.

7.4.3.3.3 "Personalized" State of Security Domain

"Personalized" state has a standard definition, it means: In this state, the security domain has possessed all the personalization data and all types of keys required for complete set of runtime environment functionality; in this state, security domain is associated with the application, so all services provided by this security domain can be used by the associated application.

"Selectable" state and "Personalized" state are not reversible. Prior to setting a security domain to "Personalized" state, it must be correctly installed.

7.4.3.3.4 "Locked" State of Security Domain

"Locked" state is used for security management control, to prevent this security domain from being selected.

Considering business or security factors, if a threat related to a particular security domain is detected, the security domain may be set to "Locked" state to prevent further selection of this security domain; access to the services provided by this security domain will also be prohibited; the security domain will no longer be able to be associated with any new executable download files or applications.

When security domain is unlocked, the security domain shall resume its state prior to being locked.

7.4.3.4 Deletion of Security Domain

In any state of the security domain life cycle, multi-application financial smart card can always receive request to delete security domain.

If multi-application financial smart card receives request to delete security domain, then all related data of the security domain must be deleted, multi-application financial smart card must not retain or leak any relevant records of the security do-

main; at the same time physical space previously utilized by the security domain can be released for reuse.

7.5 Application Security

Multi-application financial smart cards allow for many applications to co-exist on the same smart card, with the code and data of each application existing independently from that of other applications. Multiple applications can be pre-installed onto the card prior to issuance of multi-application financial smart card, and depending on business need, it can also be dynamically loaded onto the card after issuance of multi-application financial smart card. Therefore, applications include both pre-installed applications and dynamically loaded applications.

Multi-application smart card should be able to prevent unauthorized leak and modification of application code and its application data, such as software code, key, PIN, etc. An application cannot read or overwrite the data of another application without authorization, and it cannot execute without authorization the code of another application.

In order to achieve the goals above, multi-application financial smart cards must support the following mechanisms:

1. Implement logical segregation (firewall mechanism) for data used by different applications;
2. Static analysis of code prior to installation (code verification mechanism);
3. Provide code integrity protection during the code verification and installation process;
4. Use specified security service for the application:
 - 1) Utilize specified security management for keys, PIN, and other sensitive data;
 - 2) Cryptographic authentication and encryption mechanism

Application security mainly includes application code security and application data security.

Application code refers to all the application code stored within the multi-application financial smart card and running securely under the control of the multi-application financial smart card application management security framework, such as financial application code, telecom application code, government application code, transportation application code, ID type application code, electronic meter application code, etc.

Application data refers to the various types of data stored in the multi-application financial smart card that can be securely accessed and operated on during applica-

tion operation, such as application transfer key, application initialization key, application digital certificate, application communication record, log files, etc.

For sensitive application code and application data, confidentiality and integrity must be ensured to prevent illegal operations from obtaining the read-write access right to multi-application financial smart card application code and application data, leading to information leak or unauthorized changes. Examples in financial applications include the cardholder PIN code, application transfer code, digital certificate used in application transactions, etc.

7.5.1 Pre-installed Applications

Pre-installed applications refer to all pre-installed application code and relevant data stored in multi-application financial smart cards and running securely under the control of the multi-application financial smart card application management security framework, such as financial application code and data already pre-installed onto the multi-application financial smart card at the time of issuance, telecom application code and data, government application code and data, transportation application code and data, ID type application code and data, electronic meter application code and data, etc.

7.5.1.1 Application Code Security

For issued multi-application financial smart cards, pre-installed application code is installed code, first of all its security lies in the firewall mechanism that ensures the segregation between each application, preventing any application from accessing the code of another application without authorization. The main concern of designing this mechanism is the runtime security protection. Each application program has its independent operating space, with the operating space of different applications being completely segregated. Application independent secure operating protection can prevent application programs from being interfered with or modified by illegal objects. To achieve application program independent secure operating protection, complete access control must be implemented, therefore applications executing method invocation, object creation, object deletion, data access, and other operations must all follow access control strategy during the operating stage, ensuring that the application program does not go beyond its own operating environment.

Besides the above-mentioned complete segregation, firewall mechanisms can also provide controllable inter-application communication, leveraging the services of the multi-application financial smart card platform for secure information exchange as needed.

Firewall mechanism is insufficient for secure segregation of application code in and of itself. Prior to installing application code onto the card, there must be code verification, static analysis of code correctness, integrity, and validity, setting up association with authorization verification data after successful authentication. On-

ly after successful data verification by the multi-application financial smart cards could it engage in operations like application download and install.

7.5.1.2 Application Data Security

For issued multi-application financial smart cards, pre-installed application is installed application. The security of installed application data is ensured by the firewall mechanism that makes possible the segregation between each application, preventing any application from accessing the code of another application without authorization. Multi-application financial smart card must ensure application can only access hardware chip storage space through operating environment and the standardized API interface. This way the firewall mechanism could not be circumvented, ensuring that application data, such as file system, keys, etc. can be securely stored in their respective storage space, preventing malicious damage or unauthorized modification.

Besides the above-mentioned complete segregation, firewall mechanisms can also provide controllable inter-application communication, leveraging the services of the multi-application financial smart card platform for accessing other application's data as needed.

Effective and complete firewall mechanism also must be paired with code verification mechanism to truly achieve application data secure segregation, preventing application data illegal access or damage.

For securing sensitive data, special security management can be utilized, with confidentiality and integrity certification and other mechanisms further ensuring security. Select different integrity certification and encryption mechanisms through data security properties: such as verifying data integrity through data Hash value; for integrity sensitive data use characteristic value verification like MAC verification to ensure data has not been altered; for confidentiality sensitive data encryption is used to ensure there is no visible plaintext data. Data that need integrity certification and confidentiality protection include codes or data such as PIN code, user verification method related security properties, application control key, transfer key, confidential algorithm service programs, etc.

Multi-application financial smart card platform is responsible for secure allocation of storage space, when application requests resources, it must ensure that the data in the to-be-allocated storage space is invalid, so that no useful data will be leaked.

7.5.2 Dynamic Load Applications

Dynamic load application refers to all application code and relevant data stored in multi-application financial smart cards and downloaded, installed, and operated securely under the control of the multi-application financial smart card application management security framework, including, those financial application code and data that based on business need are dynamically loaded onto the multi-application

financial smart card after issuance, telecom application code and data, government application code and data, transportation application code and data, ID type application code and data, electronic meter application code and data, etc.

Dynamic load applications are different from pre-installed applications, generally only downloaded to the card after the multi-application financial smart card has been issued, and the application provider is not necessarily the issuer. At this time the download install environment is no longer a relatively closed and secure environment, therefore, dynamic load application security also includes download and install process security as well as firewall mechanism and code verification mechanism.

7.5.2.1 Application Code Security

Dynamic load application code security includes:

1. Correctness, validity, and completeness of downloaded code
2. Download and install security
3. Runtime security

7.5.2.1.1 Code Verification Mechanism

The pre-installation code verification mechanism is called static analysis of code. In static analysis code correctness, integrity, and validity is checked. after successful verification the application is associated with the authorized verification data. Then the application can be downloaded and installed on multi-application financial smart cards.

7.5.2.1.2 Download and Install Security

The security of the download and installation of dynamically-loaded application could be realized through the following means:

1. Based on which life cycle stage the application is in, different security strategy is adopted;
2. Use secure communication mechanism to establish a secure communication environment between the sender entity and receiver entity:
 - 1) Entity authentication: External entity or external entity with internal entity through identity authentication, ensure that the sender entity and/or receiver entity engaged in data exchange are trusted entities.
 - 2) Integrity certification: Multi-application financial smart cards through cryptography method ensure that the dynamic load application code from an external entity can be confirmed to be from the authenticated external entity, and the data has not been modified, deleted, inserted, or otherwise tampered with.

- 3) Confidentiality: External entity sends dynamic download application code to multi-application financial smart card via cryptogram transfer, avoiding information disclosure over plaintext transfer.
3. Based on different rights execute different legal operations.

7.5.2.1.3 Firewall Mechanism

The security of dynamic load application code during operation is ensured by the application firewall mechanism, for details see Section 7.5.1.1 "Application Code Security".

7.5.2.2 Application Data Security

Dynamic load application data security includes:

1. Correctness, validity, and completeness of downloaded application
2. Download and Install Security
3. Operating security
4. Security management particularly for security sensitive data

7.5.2.2.1 Code Verification Mechanism

Static analysis of code prior to installation, known as the code verification mechanism. Static analysis of code for correctness, completeness, and validity, after successful verification associate with authorization verification data, with multi-application financial smart card only able to download, install or otherwise operate the application after the data verification is successful; act in conjunction with effective and complete firewall mechanism to truly deliver application data secure segregation, preventing application data from being illegally accessed or damaged.

7.5.2.2.2 Download and Install Security

Dynamic load application data download and installation security could be realized through the following means:

1. Based on different life cycle stage, use different security strategy;
2. Use secure communication mechanism to establish a secure communication environment between the sender entity and receiver entity:
 - 1) Entity authentication: External entity or external entity with internal entity through identity authentication, ensure that the sender entity and/or receiver entity engaged in data exchange are trusted entities.
 - 2) Integrity certification: Multi-application financial smart cards through cryptography method ensure that the dynamic load application code from an external entity can be confirmed to be from the authenticated external

entity, and the data has not been modified, deleted, inserted, or otherwise tampered with.

- 3) Confidentiality: External entity sends dynamic download application code to multi-application financial smart card via cryptogram transfer, avoiding information disclosure over plaintext transfer.
3. Based on different rights execute different operations.

7.5.2.2.3 Firewall Mechanism

The security of dynamic load application data during operation is ensured by the application firewall mechanism, for details see Section 7.5.2 "Application Data Security".

7.5.2.2.4 Security Management Particularly for Sensitive Data

Dynamic load application data, in terms of security management of security sensitive data, is similar to pre-installed applications, for details see Section 7.5.2 "Application Data Security".

8 Multi-application Financial Smart Card Security Requirements

8.1 Multi-application Financial Smart Card Security Environment

Multi-application financial smart card security environment mainly includes:

1. In the development stage, all development activities must be access controlled and traceable; and in this stage all participating staff must fully understand and strictly execute established security process.
2. In each stage of the multi-application financial smart card life cycle, must be able to control the security of related material information transfer and storage process for multi-application financial smart card:
 - 1) In the transfer and storage process, must be able to ensure the security of multi-application financial smart card related material information;
 - 2) In the transfer and storage process, if incorrect operation occurs must be able to ensure reasonable measures be taken;
 - 3) In the transfer and storage process, must be able to ensure the personnel responsible for transfer have the necessary skills.
3. In the development stage, IC circuit manufacture stage, smart card manufacture stage, smart card issuance and personalization stage, must be able to ensure suitable functionality testing; and utilize secure steps in all manufacturing and testing to maintain the confidentiality and integrity of production test data (such as preventing possible copying, modification, theft, personal retention, or unauthorized usage, etc.), with importance given to thorough processing of waste data, such as thorough electronic erasure and complete shredding of files; also, must be able to ensure the traceability of the entire process.
4. In the smart card end user stage, must be able to ensure use of secure communication protocol between the smart card and the terminal and corresponding synchronization; at the same time provide application development guides and manuals to application providers for post-download application development.

8.2 Security Threats and Attacks

Multi-application financial smart cards must be able to defend against the following security threats and attacks:

1. Unauthorized complete or partial cloning of multi-application financial smart cards.
2. In the development stage, there are three types of security threats and attacks that must be considered:

- 1) Attack on smart card embedded software and its development environment, such as unauthorized distribution, modification, theft, or unauthorized usage of smart card embedded software and/or initialization data;
 - 2) During embedded software development, attack on the transfer of materials from the IC designer to the software developer;
 - 3) In the process of transferring materials from the software developer to the IC designer, attacks on the smart card embedded software and/or initialization data.
3. In the process of the data transfer from smart card developer to IC packaging merchant, manufacturing merchant, or personalization vendor, attacks on the data, such as unauthorized distribution and modification of pre-installed application and embedded software private data.
4. In the smart card manufacturing stage or smart card issuance and personalization stage, there are three types of security threats and attacks:
- 1) Unauthorized distribution of embedded software, pre-installed application and data (such as data protection system, storage region management, cryptography program, keys, etc.);
 - 2) Theft of unauthorized use of embedded software, pre-installed application and data, attempt to access relevant materials or executing non-permitted operations (such as attackers attempting to obtain access smart card system through fraud, or maybe using unauthorized means to personalize smart cards, etc.);
 - 3) Unauthorized modification or damage to security functionality data; unauthorized download or illegal modification of pre-installed application; illegal execution of multi-application financial smart card platform or application software; illegal modification of platform or application program behavior through interaction of different programs; unauthorized modification of smart card embedded software and data.
5. Security threats and attacks relating to loadable applications:
- 1) Loading application onto multi-application financial smart card without permission, this may lead to illegal usage of card resources and attacks from unverified applications on other applications and user data within the multi-application financial smart card;
 - 2) An application that pretends to be another loadable application is downloaded onto multi-application financial smart card, this may lead to attacks on card resources and user data;

- 3) Download a loadable application corresponding to a specific security domain into another security domain, this may lead to lower security for this application, thereby impacting application data security;
 - 4) Monitoring application downloads and changing code and data without application provider permission;
 - 5) Monitoring application download and obtaining access to application secret code or data;
 - 6) Loading an application by overwriting part or all of another application, leading to damage or illegal access to the other application's code or data.
 - 7) Deleting loaded application without permission;
 - 8) Deleting a loaded application such that the secret code and/or data are still in memory and searchable;
 - 9) Deleting a loaded application also deletes part or all of another loaded application;
 - 10) Use a loadable application to read secret code or data belonging to another downloaded application;
 - 11) Without authorization, use a loadable application to modify the secret code or data belonging to another downloaded application;
 - 12) Damaging card resources.
6. In the smart card end user stage, unauthorized distribution, unauthorized modification or damage to user data (including application provider and terminal user) and security functionality data.

8.3 Security Goals

Multi-application financial smart cards must be able to achieve the following security goals. In order to achieve these security goals, if corresponding IC circuit physical security characteristics are provided, then specifications relating to these IC circuit physical security characteristics should also be considered; if corresponding IC circuit physical security characteristics are not used, then must use other means to realize the following security goals.

1. Prevent tampering with multi-application financial smart card key security components. Especially for functionality parameters, security properties, life cycle serial ids, encryption keys, etc., security mechanisms are required to prevent unauthorized modification.
2. Embedded software design must achieve: embedded software could not be decomposed through hardware component electrical signals.
3. Multi-application financial smart cards must be protected against cloning.

4. Ensure persistent and correct operation of security functionality.
5. Ensure the security mechanism for embedded software is not distributed through unauthorized means.
6. Ensure sensitive data stored in various types of memory are not distributed through unauthorized means.
7. Ensure sensitive data stored in various types of memory are not damaged or modified through unauthorized means.
8. Even if previous download process or deletion process resulted in errors, prior to loading of a loadable application, multi-application financial smart card must still be in a defined valid state. Error in download process or deletion process must not impact multi-application financial smart card resources, this kind of rollback mechanism can be automatically realized or through specified commands.
9. Must provide some means to control user utilized resources, to prevent some user permanently taking up some resources in an unauthorized fashion leading to other users to be rejected due to insufficient resources. Control of a loaded application over permanent memory (ex. EEPROM) must be able to be stopped if necessary, because this would lead to other loaded applications being unable to utilize these resources.
10. Loadable application can only be downloaded onto multi-application financial smart cards with permission.
11. If needed, application download process must be able to ensure confidentiality, completeness, and can verify the legality of loadable application code and data.
12. Downloading an application must not impact existing application code and data.
13. Deleting a loadable application recovering its application for reuse can only happen with permission, and this space must not retain any data related to application code and data that should be deleted.
14. Deleting a loadable application must not have any impact on the remaining independent application code and data.
15. Each loadable application must be mutually segregated. A loadable application must not be able to read or write the code and data of another loadable application without authorization.

8.4 Security Requirements

8.4.1 Security Functionality Requirements

Based on the above mentioned security threats and attacks and the security goals to be achieved for multi-application financial smart cards, this section defines corresponding security functionality requirements.

1. Security check warning:
 - 1) Multi-application financial smart card must be responsible for detecting potential security threats.
2. Security check analysis:
 - 1) Multi-application financial smart card should be able to utilize a set of rules to monitor events under investigation, this set of rules targets potential security threats in particular;
3. Encryption key management:
 - 1) Encryption key access: Multi-application financial smart cards must be able to process different encryption key access types according to specified key access methods, so long as these specified key access methods meet required standard specifications;
 - 2) Encryption key disposal: Multi-application financial smart cards must be able to destroy encryption keys according to specified key disposal methods, so long as these specified key disposal methods meet required standard specifications;
4. Cryptographic operations:
 - 1) Multi-application financial smart cards must be able to follow specified key algorithm and key lengths to execute various cryptographic operations, these specified key algorithms and key lengths meet required standard specifications;
5. Access control functionality:
 - 1) Multi-application financial smart card must be able to enforce implementation of various security strategies based on different security properties or security group properties;
 - 2) Multi-application financial smart card must be able to decide whether the operation between the controlled subject and object is allowed based on corresponding rules.
6. Data authentication:

- 1) Multi-application financial smart card must be able to generate authentication value used in verifying data validity;
 - 2) Multi-application financial smart cards must be able to verify data validity through verifying authentication value.
7. Residual data protection:
- 1) Multi-application financial smart card must ensure the prior data content in resources are not disclosed.
8. Rollback:
- 1) Multi-application financial smart card must be able to rollback specified operations on specified objects;
 - 2) Multi-application financial smart card must be able to permit specified operations to be rolled back within a specified scope.
9. Storage data integrity:
- 1) Multi-application financial smart card must be able to monitor stored user data for integrity errors based on user data properties;
 - 2) Once data integrity error is detected, must take specified measures;
10. Authentication error processing:
- 1) Multi-application financial smart card must be able to detect the number of error retries for particular specified authentication events;
 - 2) When the number of error retries reach or exceed specified threshold, multi-application financial smart card must be able to take specified measures.
11. User authentication:
- 1) Prior to user passing authentication, multi-application financial smart card must permit engaging specified operations;
 - 2) Besides the operations specified above, multi-application financial smart card must require successful user authentication before engaging other operations.
 - 3) Multi-application financial smart card must prevent authentication data from specified authentication mechanism being reused.
12. Security functionality action management:
- 1) Multi-application smart card must strictly restrict the start, close, and modification of security functionality actions to within the pre-authorized role scope.
13. Security property management:

- 1) Multi-application smart card must strictly restrict the browsing, modification, and deletion of security properties to within the pre-authorized role scope.
 - 2) Multi-application financial smart card must ensure only secure reliable values can be accepted for use as security property value.
 - 3) Multi-application financial smart card must provide default values for compulsory execution of security functionality strategy;
 - 4) When an object or data is created, multi-application smart card must permit initial values defined as changeable in authorized roles to replace default values.
14. Security functionality data management:
- 1) Multi-application smart card must strictly restrict the browsing, modification, and deletion of security data to within the pre-authorized role scope.
 - 2) Multi-application smart card must strictly restrict the upper and lower value limits of security functionality data to within the pre-authorized role scope.
 - 3) If security functionality data reaches or exceeds designated upper and lower value limits, multi-application financial smart card must be able to take specified measures.
15. Secure management role:
- 1) Multi-application financial smart card must maintain management of authorized roles;
 - 2) Multi-application financial smart cards must be able to authorize association of roles and users.
16. Non-observability:
- 1) Multi-application financial smart card must ensure user and/or entity could not observe the operation of protected object, including the mechanism, user data used, and user data processing.
17. Security in event of errors:
- 1) When errors of specified types occur, multi-application financial smart card must maintain a secure state.
18. Secure functionality physical protection:
- 1) Multi-application financial smart card must defend against physical damage to security functionality equipment/component through automatic responses.
19. Trusted recovery:

- 1) Multi-application financial smart card must be able to ensure: security functionality or complete execution success, or for a designated error scenario recover to a uniform and secure state.
20. Non-circumvention of security strategy:
 - 1) Prior to each security functionality is permitted to be executed, multi-application financial smart card must ensure security strategy is compulsorily invoked and successfully executed.
21. Domain segregation:
 - 1) Multi-application financial smart card must maintain security domain to protect applications in the security domain from interference and damage due to un-trusted entities;
 - 2) Multi-application financial smart card must enforce the segregation between security domains.
22. Resource allocation:
 - 1) Multi-application financial smart card must enforce max allocation restrictions on controlled resources, making sure that resources utilized by individual users and user groups are restricted in a certain scope during the same period or within some specified time period.

8.4.2 Chip Security Requirements

Loading of multi-application smart cards must meet: chips must meet the highest requirements of all card internal application on chip security specification. Ex.: Application A specification requires the application to use EEPROM as data storage medium, application B specification permits application to use EEPROM or FLASH as data storage medium, then smart cards simultaneously loading application A and application B must use EEPROM as the application storage medium.

8.4.2.1 Anti-Tamper Capabilities

The chip of the multiple-application cards shall have some anti-tamper capabilities to make it difficult for the attacker to obtain or alter the confidential data within the chip through direct physical attacks. For example, when the attacker adopts the chip reverse analysis or physical probing or any other means to destroy the internal data of the chip, the chip must be able to effectively stop such operations.

8.4.2.2 Anti-Side Channel Attack

The multiple-application cards must be able to resist the side channel attacks, and prevent the information leakage during card operations, such as preventing the internal data of the cards from being acquired by the attacker through time, power dissipation, clock and other information. At the same time, the IC cards shall be

able to effectively prevent the internal confidential data from being deduced by the attacker through complex analysis methods, such as the differential power analysis.

8.4.2.3 Anti-logic Attacks

The multiple-application cards must provide an anti-logic attack mechanism. The IC cards must be able to detect attacks, such as fault injections, replay attacks, unauthorized program downloads and invalid input data by the attacker, and provide effective protection.

8.4.2.4 Safe Recovery

When an IC card is powered off or the card reader is pulled out during the application operation, the card operation system must have a safe recovery mechanism to allow the application to be continued correctly when the card is powered on next time or return to the status before it is executed, So as to guarantee the IC card is always under a stable and safe status.

8.4.2.5 Anomaly Detection

The IC Cards provide an anomaly detection mechanism to detect or identify anomalies and timely inform the card operation system in case an anomaly occurs, including adopting the environmental detection circuit to resist fault injections by the attacker. The card operation system is able to deal with anomalies occurred in the application and identify their types as well as carry out corresponding operations.

8.4.2.6 User Authentication Method

The generation, maintenance and usage of user authentication data are out of the protection scope of the multiple-application cards. Therefore, these operations must be conducted in a safe mode to prevent leakage or alteration of the authentication data. For example, when a multiple-application card receives the user authentication data from outside, a safe channel must be adopted to transmit the authentication data in encrypted form.

The user authentication method data cannot be changed freely by applications within the multiple-application cards, except for applications with special authority.

8.4.2.7 Application Programming Interface

An application must schedule the system resources through the application programming interface provided by the IC card platform. During the application operation, the IC card shall be able to prevent the illegal scheduling of applications.

8.4.2.8 Application Code Verification

An out-of-card application must go through the application code verification and be correctly compiled via the application programming interface. The illegal schedules are forbidden. After the application has been successfully verified, it shall be linked to the authorization verification data. Only after the multiple-application card has

been successfully verified, can the application document be downloaded and installed.

8.4.3 COS Security Requirements

8.4.3.1 Inherent Protection Mechanism of the COS

The regulations and requirements concerning the security protection of multiple-application cards are mainly intended for the already-issued cards. The COS and some preset applications have been installed in the cards before their issuance. The applications may be added, deleted or altered after such cards have been issued. This section aims to guarantee the safe downloading, deletion and operation of applications after the cards have been issued.

8.4.3.2 Security Guidance

The security guidance for the IC cards describes a series of predefined operations that must be executed before the cards are used.

The security guidance may prevent an IC card from being used before the protection measures are initiated or before the protection code is operated to ensure the card enters a safe and controllable operation state after being powered on.

The security guidance requires the execution of a series of predefined operations, including proper authorization and status conversion setting, before the IC card is used, to ensure the improper interactions or other elements during the life cycle operation are not exploited by illegal users.

The security guidance is intended to resist unauthorized access, and ensure the legally authorized users may use the IC cards safely.

8.4.3.3 Safe Recovery

The COS of the IC cards provides a safe recovery function to ensure the atomicity of operations. The atomicity means during a transaction processing, all relevant data are updated or un-updated. Before and after the transaction processing, the application state shall be consistent.

The safe recovery protection mechanism shall not influence the execution of application programs. During a transaction, if an application program is suspended, the COS of the IC card shall be able to restore the data of the application program to the state before the transaction.

The safe recovery protection function shall support the atomicity of a single datum and multiple data, and must support nested transactions. A nested transaction is a transaction that is started within the scope of an already started transaction. The submission and termination of the new transaction does not influence processing of the previous transaction. If the application program is suspended, roll back all operations to recover all data of the nested transaction.

8.4.3.4 Registry Service

The COS of multiple-application cards provides registry services. The COS registry is a hierarchical database for retrieval purpose. It stores all resource information, management information and other important data of the card, including:

IC card resource management information, including information about application programs and the COS's software and hardware resources;

configuration information of applications, such as identifiers of application programs, application programs and key management,

linkage information between application programs and security environments;

And life cycle information of applications and the COS.

The contents of the registry may be automatically updated by the COS program or by execution of an authorized operation.

8.4.3.5 Safe Communication Mechanism

The platform of the IC cards is able to provide a safe communication mechanism or a non-safe communication mechanism as required by an application program.

The safe communication mechanism provided by the COS may serve the following purposes:

Entity authentication: the communicating parties, including entities in and out of the card, must go through identity authentication.

Primary Evidence: the primary evidence shall be generated by the sender for data transmission, based on which, the receiver may verify the integrity of data received.

The COS provides data integrity verification to prevent the communication data from being altered, deleted or inserted.

Confidentiality: the COS provides data confidentiality protection to prevent the confidential data from being leaked.

When an application does not need the security protection mechanism, the COS of IC cards may provide a non-safe communication mechanism to establish a communication channel for both parties, however, the integrity and confidentiality of data transmitted this way are not guaranteed.

8.4.3.6 COS Memory Management

The COS memory management and protection functions are intended to protect the integrity and confidentiality of data within the memory of the IC cards. The COS memory management and protection mechanism is applicable to various memories within the IC cards, including the volatile memory and the permanent memory, such as RAM and EEPROM.

The COS memory management and protection functions provide protection for the integrity and confidentiality of sensitive data based on their security attributes. Such as verifying the data integrity based on their Hash value; guaranteeing the data are not altered through carrying out characteristic value verification such as MAC, upon integrity-sensitive data; and encrypting confidentiality-sensitive data to make them invisible.

Data that need to be protected for their integrity and confidentiality include: PIN codes, relevant security attributes of the user authentication method, the application usage key, the transmission key, the encryption algorithm service programs and other codes or data.

The COS memory management and protection functions shall guarantee a safe allocation of memory space. When an application applies for resources, it must be guaranteed that the previous information within the memory block is invalid.

The COS memory management functions must be capable of controlling the resource allocation, preventing beyond-quota resource applications and preventing the resources from being exhausted.

8.4.3.7 COS State Management

The state management functions of the IC cards must guarantee the improper interaction functions during the life cycle of the IC cards cannot be used illegally. Even if the data obtained by an IC card in different states have been acquired by an unauthorized user illegally, the security of the card shall not be compromised.

The COS state management and protection functions provide data access based on security attributes. Only authorized users may read or alter the security attributes, namely, the state. The COS state management and protection functions allow the authorized users to define the security attributes or cancel relevant security attributes of a security state.

8.4.3.8 Attack Detection

The COS provides the attack detection and protection functions:

The COS is capable of detecting resources, to prevent them from being intentionally exhausted by the attacker. When the COS detects that an application program constantly applies for resources which are beyond the quota, it may automatically lock up the application.

The COS is capable of verifying whether the received command conforms to the current life cycle.

The COS shall guarantee its security functions are effectively executed, that is to say, the security functions are not bypassed. When detecting some security functions are being bypassed (for example, the authentication process is bypassed), it may adopt proper operations to prevent the card from being further jeopardized.

8.4.3.9 Security Audit

When detecting a potential security violation, the COS of the IC cards will automatically execute security audit operations. If the card is under attack, the COS will provide card-locking service or set the attacked application to lock state to avoid further escalation of damages.

The COS adopts the card-locking operation as a security control practice to stop the operation of all applications within the IC card. When the COS detects a threat to the card, it shall be able to set itself as locked; the application program with reasonable authority shall also be able to lock the COS; both the issuer and institutions with this authority may also lock the card according to their needs.

Once a card is locked, only the card issuer and the properly-authorized institutes have the authority to the recover the card state.

8.4.3.10 Cryptographic Algorithm Services

8.4.3.10.1 Key Generation

The COS of IC cards will generate different types of session keys according to the requirements of the security channel, with the key length meeting the specified criteria. The key generation and protection functions support various types of cryptographic algorithms, and are able to resist replay attacks and threats of unsafe communications. The cryptography standards include ANSI X 9.52 and FIPS 46/3.

8.4.3.10.2 Key Distribution (Transmission)

The COS of the IC cards will distribute static keys according to a specified key distribution method. Before the COS enters the safe state, the initial key must be installed in the IC cards safely. The key of the COS needs to be transmitted via the secure encrypted-channel established using the initial key. In addition to confidentiality requirements for the key transmission, the secure channel shall also provide an integrity mechanism to ensure the key is transmitted correctly, such as providing the key check mode.

8.4.3.10.3 Key Storage

The COS of the IC cards provides a safe key storage mechanism to prevent the key from being disclosed, altered or substituted.

8.4.3.10.4 Access to the Key

The COS of the IC cards only allows safe access to the key through special methods, such as submitting an authentication request beforehand, and following the successful authentication, accessing the key data via the secure channel that provides integrity and confidentiality services.

8.4.3.10.5 Key Destruction

The COS of the IC cards adopts specified methods to destroy the keys, such as the overriding method and the erasing method, etc. The access to an already-eliminated key will lead to abnormal operations of the program.

8.4.3.10.6 Cryptographic Algorithm Operations

The cryptographic algorithm operations may be roughly classified into 3 categories:

--Encryption Algorithm

The COS of the IC cards provides symmetric key algorithms, such as the DES, AES and 3DES.

The COS provides asymmetric key algorithms, such as RSA.

--Authentication Algorithm

The COS of the IC cards provides authentication algorithms for the authentication of IC cards and the host, as well as the application authentication authorization, such as the RSA signature verification algorithm and the DSA signature verification algorithm or verifying the authentication data through a session key generated after consultation.

-- Information Verification Algorithm

The COS of the IC cards provides the information verification code MAC algorithm for the integrity of transmitted confidential data or provides value verification method, such as the HASH algorithm to Realize the check of data integrity.

8.4.3.10.7 Application Scheduling

The COS of the multiple-application cards provides the application scheduling function, to allow the external devices to select and execute applications within the card under safe conditions of the COS. The application scheduling function of the COS is selected and executed through the application AID. After an application program has been successfully selected, the COS will send the received follow-up commands to the current application for processing.

When an external device selects a new application, if there is only one channel, the COS of the IC cards will automatically terminate the previous application and empty all residual data left; otherwise, the COS will keep the execution environment of the previous application and allocates a new memory space for the new application.

8.4.3.10.8 Identification and Authentication

The COS of the IC cards provides an identification and authentication protection mechanism.

The authentication process is a process where the party applying for authentication provides the identity certificate or security attributes, such as the application identifier, the life cycle status and the authorization code of the out-of-card entity, and the party providing the authentication service determines the identity of the applier based on the identity authentication results and determines whether to authorize rights to the applier, such as the rights to access the resources.

To access special resources within the IC card, an application program must provide the identity information about itself for the COS to make an authorization decision. To access the IC card, an out-of-card identity also has to provide the identity information about itself, based on which, the COS will carry out identity identification and execute authentication operations.

8.4.3.10.9 Application Programming Interface

The COS of the IC cards controls the access to card resources through the COS application programming interface.

The utilization of COS services and resources by an application program must be achieved through the predefined application programming interface.

The functions of the application programming interface include: providing secure channel services, such as providing encrypted and decrypted data and setting the attributes of the secure channel, and memory services, such as providing access to different types of memories, acquiring the COS state, suspending the operation of the COS or an application and obtaining the cryptographic algorithm services, etc.

Smart cards loading multiple applications must separately meet the security requirements of each application in its environment, including encryption algorithm, personalization, etc.

Once an application is created, this application can be securely deleted. Entities with rights can execute application deletion operation, entities with rights include card issuer and authorized organization and agency organizations authorized or entrusted by the card issuer.

MF as the root of smart cards, owns the card control key. Card control key can be used as the control key to control the creation of application environment and load application environment. In multi-application cards, card control after completing creation of application environment control key, immediately loses control rights over the application. Subsequent application key loading, update, and application files and ADF creation are controlled by the application environment control key.

8.4.4 Multi-application Financial Smart Card Security Protection Requirements

Smart card loading of multiple applications must meet: "application item segregation, no mutual impact" security principle.

Specifically, firewalls must exist between the applications loaded within the smart card, so any operation by one application (including card locking) would not impact the data in other card applications and the existing state of other applications. Within any particular application, using another application's key to operate on internal data of this application is viewed as illegal.

8.4.4.1 Multi-application financial smart card application security requirements grades.

8.4.4.1.1 Installation

The application programs may be added in multiple ways according to the management pattern of the IC cards.

The adding of an application program is a type of input of user data with security attributes. When an application program is imported from outside the IC card security control scope into the card, the access control must be executed. The newly added security attributes of the application program include the identity and application identifiers of the downloader. The identity authentication process for the application downloader is different under different IC card management patterns.

The simplest situation is that the card issuer is the sole card management agency, and the responsibilities for the security of the download and installation of application programs entirely reside with the card issuer. The card issuer will conduct authentication on the host where an application program is downloaded to ensure the security and confidentiality of the application file transmitted between the card and the host. The card issuer will also conduct checks upon the legitimacy of the execution of the application code. Upon receiving an application file download command, the platform of the IC card only needs to identify the identity of the card issuer before executing the application file download and installation operations.

If the card issuer has authorized any other agency to take care of the application and download issue, the authorized agency shall be responsible for the communication security between the card and the host for application downloads. When an application is downloaded to the IC cards, the platform of the IC cards will execute the authority verification. Only after the verification has been successfully conducted, may the application download function be executed and a necessary memory space be allocated for the application.

If the card issuer has authorized any other agency to act as an agent, the agent does not need to conduct authorization verification when an application file is downloaded. The platform of the IC cards only needs to check the token contained in the application file to be downloaded.

When the addition of an application program fails, the platform of the IC cards can guarantee that the card will be recovered to the safe state before the application installation.

The application programs may be identified by a unique identifier.

Each application program in the multiple-application cards has its unique identifier. The platform will use the identifiers of application programs as application security attributes when executing access control. When the platform executes application scheduling, the unique identifiers of application programs are used to link applications.

There are various types of application programs.

They may be classified into several categories with different authority:

General type: such as financial applications and telecom applications. This type of applications may schedule the basic service programs via the application programming interface provided by the platform, such as the cryptographic algorithm service and channel service program.

Installation type: programs which are able to provide installation services for application programs. This type of applications may schedule the cryptographic algorithm service or add the cryptographic authentication algorithm to provide verification programs for the installation of new applications.

Service type: providing basic services, such as algorithm programs, some library functions and functional functions. This type of applications may schedule the basic service programs via the application programming interface provided by the platform and add new service programs to the platform, such as the algorithm program and library functions.

The application programs have different authority.

The authority of an application program provides a basis for the platform of the IC cards to execute the security function. The application programs with different authority may operate the card resources in different manners. The application authority is mainly classified into several categories as follows:

Memory management: able to conduct card memory management;

Channel management: to receive the channel command through the input/output channel;

Cryptographic algorithm management: able to execute cryptographic operations, key management and execution of the secure channel.

The application programs have their own linked key management mechanisms.

Each application in the multiple-application cards is linked with the same or different key management mechanisms.

Each key management mechanism includes the key type, key number, key storage and key access functions required by the application.

An application may set its own key management mechanism on the platform of the IC cards, such as the safe deposit of initial keys of different application programs and encryption of confidential data using different types of keys or the same key during application execution.

The application programs have their own installation verification modes.

The application programs have their own linked authorization verification data at the time of download. The authorization verification data coming along with the downloaded application file will be verified via the key management mechanism linked to the application. The out-of-card applications may be downloaded to the IC cards only after having passed the authorization verification.

The application programs have their own symbol tables.

Each application program in the IC cards has its own symbol table.

The application symbol table includes the functions and mappings of their corresponding addresses and types of variables, parameter address and memory allocation information within the program.

The application symbol table provides a guarantee for the isolation of application program codes, to prevent an application program from overriding the space of other application programs or accessing the code or data of other application programs cross the boundary.

The application programs have their own application namespaces.

Each application program has its own application namespace. The application operation or access to the application resources may be only executed within its own namespace.

For example, if there is a file 1.txt in both the application A and the application B, but due to the protection of application namespace, the application A, when executed, may only access to the file 1.txt within the application A, namely, A_1.txt, in a way to prevent the wrong access to application resources.

Initialization

The application programs have their own linked initializations

After an application program has been downloaded and installed, it generally needs to acquire its own personalization data, including the application execution key and the user-specific data. The platform of the multiple-application cards enables an application program to have its own linked initialization. Different application programs may select different initializations.

The application program initialization will establish a personalized secure channel for an application, conduct necessary verification upon the subject downloading personalized data and provide necessary decryption for the communication key. The application uses its own initialization services to guarantee the security of the downloaded personalized data.

8.4.4.1.2 Operation

The application programs may operate safely and independently.

Each application program has its own independent operation space. The operation spaces of different applications are totally isolated. To protect the independent and safe operation of an application program may prevent the application program from being disturbed or altered by illegal objects.

To protect the independent operation of an application program, the access control must be executed completely, that is to say, the operations, such as the scheduling of execution methods, object creation, object deletion and data access, have to follow the access control strategy to ensure the application program will not leave its own operation environment.

The application programs may communicate with each other safely.

As the application programs are isolated by the code space and the operation environment, they cannot communicate with each other directly under different environments. Their communication must be achieved through the communication service provided by the platform.

The platform of the IC cards may achieve the communication between applications through providing shared interface objects and functional services based on the shared interface mechanism, such as the event notice function.

An application needs to schedule the platform API to conduct shared interface object registration. The shared interface object registration or registration cancelation may be conducted by the application in a static or dynamic manner. When an application schedules a shared interface object provided by other applications, it needs to seek the services through the platform, which will return the shared information.

The application programs have their own linked security environments.

Each application program in the multiple-application cards has its own linked security environment. The application security environment provides the storage service for security data and security algorithm services.

The security environment of an application is responsible for establishing a secure channel for the application operation, providing the session key and maintaining the application execution state. Different applications may establish and manage different security environments, such as selecting different types of algorithms to

conduct transmission of encrypted data or adopting the signature mechanism to ensure the non-repudiation of data transmission.

The application programs have their own states

The application programs have different states, including the installation state, personalization state, ready state, selection state, lock state and deletion state.

The application programs may execute different operations according to different states. For example, in the application personalization state, a special secure channel shall be established to upload and transmit application data and the key. In the application selection state, a corresponding application processing process will be executed according to the command received.

The application programs may be reconfigured.

It means the application programs may change their own linked key management and security environments.

An application program was automatically linked to a key management mechanism at the time of installation. The application provider may change the mechanism to another key management protection mechanism after the application has been installed or set a new key management mechanism and link it to the program according to actual needs.

Similarly, an application program may be linked with its own security environment at the time of operation. The operation security environment may be also reconfigured.

The reconfiguration of an application program needs to follow different operation processes according to the execution mode of the multiple-application cards. First, the platform of the IC cards needs to detect whether the life status of the platform is under the non-lock and non-termination state, then verify whether the subject carrying out configuration has the reconfiguration authority (including the scope of authority or token verification); then determine whether the new key management protection mechanism is valid and may be linked with the application program. After the successful verification, the platform will update the registry information and complete the reconfiguration.

The application programs may be deleted safely.

The application programs in the multiple-application cards may be deleted safely. Only subjects having authority may delete applications. It includes the card issuer and agencies authorized or agents entrusted by the issuer.

The application deletion may be a physical deletion or logic deletion. If an application is within the nonvolatile memory block, it may be deleted completely; if it is within the permanent memory block, it may be only deleted logically. Any and all

access to the memory space of a deleted application is illegal. After an application has been deleted, the residual data will be overridden or forbidden to be accessed.

8.4.4.2 Multi-application financial smart card user security requirements grades.

The multiple-application cards support the user management and protection function to ensure the current users of the cards are the card holders. In this Specification, the global PIN code is used to achieve the user authentication. The global nature of the PIN code is that when the PIN code of an authorized application is changed, all applications within the card will be influenced.

The user management and protection function mainly provides two kinds of services: authentication and management. All applications may access the authentication service but only authorized applications may schedule the management service.

The management service includes the setting of initial value and access to relevant security attributes, such as acquiring the times of authorization, and recovering the lock state to the available state as well as re-setting the initial value. The management service also includes the application execution mechanism that supports the user authentication method, for example, before an application program is operated, the PIN code verification must be conducted, no matter whether the PIN codes of previously operated applications have been correctly verified. If the PIN code passed the verification in a session, all application programs in the card may be operated right away.